

CI/CD con enfoque DevSecOps

Caso Forseti — Facturación electrónica SRI Ecuador

Hernán Jurado · Sebastián Cruz

Ingeniería en Software · UDLA · Facultad de Ingeniería y Ciencias Aplicadas
ISWZ3205 · Procesos de Software · Julio 2026

github.com/TARIUS-S-A-S/forseti-devsecops

1 • El problema

Forseti es un SaaS de facturación electrónica **en producción real** que emite comprobantes al SRI Ecuador firmados con XAdES-BES.

Tres riesgos combinados

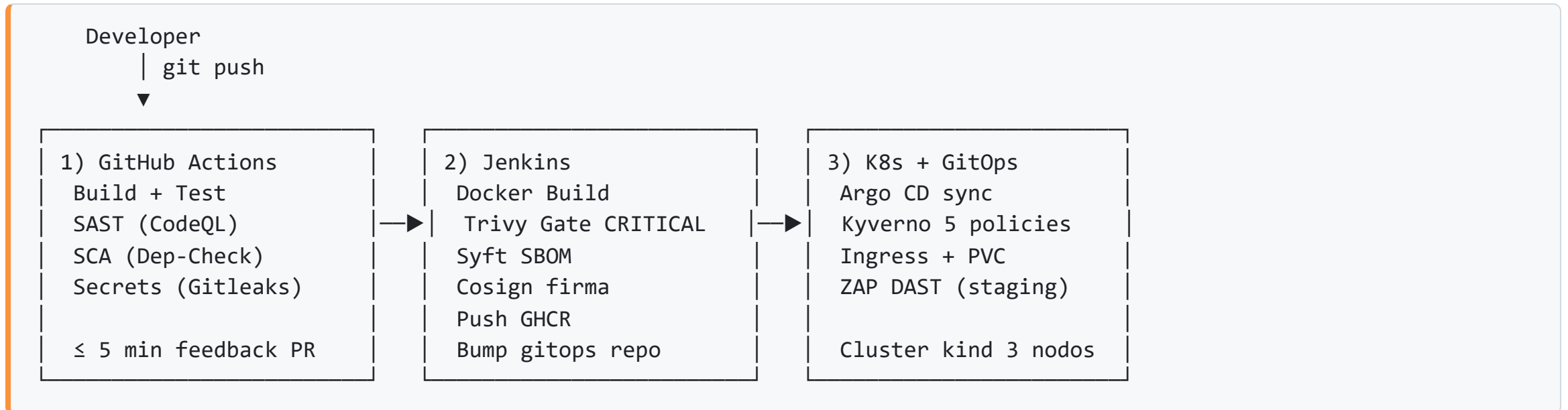
- **Compliance LOPDP** — procesa RUCs, direcciones, correos: datos personales bajo la Ley Orgánica de Protección de Datos del Ecuador.
- **Certificados digitales** — maneja `.p12` privados cifrados con AES-256-GCM. Un fallo de firma corrompe la validez fiscal del documento.
- **Cadencia alta** — la base tributaria SRI cambia 2 veces al año. No podemos frenar los releases mientras arreglamos seguridad.

Pregunta guía

¿Cómo entregamos rápido sin aflojar la seguridad?

Respuesta → un pipeline con **DevSecOps integrado en cada etapa** — no al final del ciclo.

2 · Arquitectura en 3 capas



Regla de oro: cada herramienta hace lo que hace mejor. **Nada se pisa.**

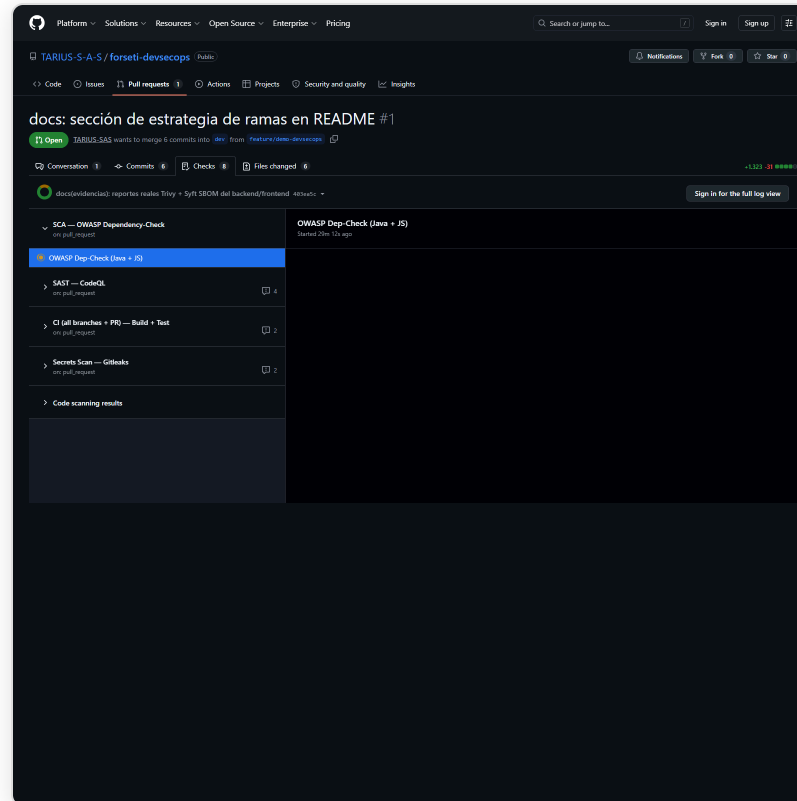
3 · Matriz de herramientas — sin redundancia

#	Etapas	Herramienta	Rol único (que las demás NO cubren)
1	CI orquestador	GitHub Actions	Feedback en el PR (≤ 5 min)
2	SAST	CodeQL	Bugs de código Java + TS sin ejecutar
3	SCA (deps)	OWASP Dep-Check	CVEs en <code>pom.xml</code> + <code>package-lock</code>
4	Secrets	Gitleaks	Credenciales en historial Git
5	CD orquestador	Jenkins	Release engineering con gates
6	SCA (imagen)	Trivy	CVEs en OS + libs de la imagen
7	SBOM	Syft	Inventario SPDX de cada imagen
8	Signing	Cosign (Sigstore)	Firma keyless + key-based
9	GitOps CD	Argo CD	Sync declarativo del cluster
10	Policy	Kyverno	Admission control YAML-nativo
11	DAST	OWASP ZAP	Vulns en runtime del deploy

11 herramientas, 11 responsabilidades distintas. Descartadas: GitLab CI, Snyk, Notary v2, OPA/Gatekeeper, FluxCD.

4 · CI en GitHub Actions — evidencia real

5 workflows en paralelo por PR (feedback ≤ 5 min): SAST CodeQL · SCA Dep-Check · Secrets Gitleaks · CI Build+Test · CD por rama. **Branch protection** en `main` obliga 5 status checks verdes.



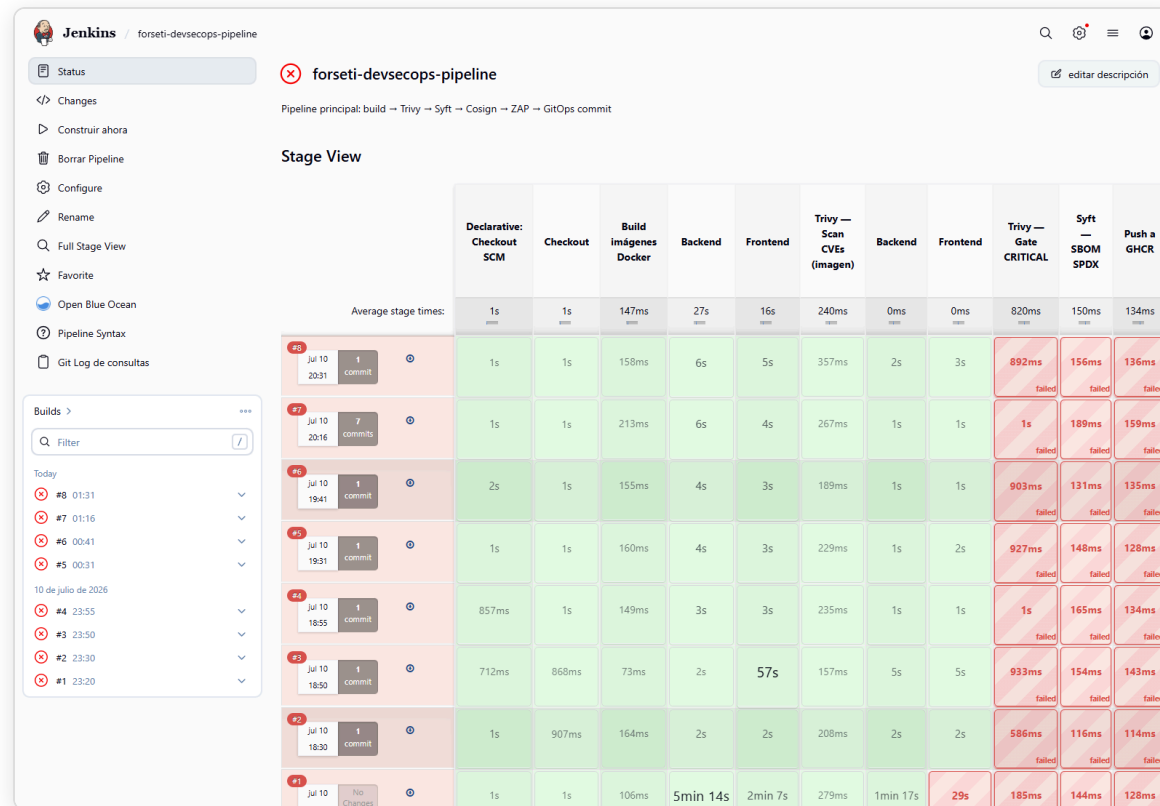
PR #1 real — status checks del pipeline visibles en el sidebar

5 · Jenkins — Stage View del pipeline

9 stages: Checkout · Build imágenes Docker (paralelo BE/FE) · Trivy Scan · Trivy Gate CRITICAL



· Syft SBOM · Push GHCR · Cosign firma + attest · ZAP DAST · Bump GitOps.



Jenkins corre en Docker con Trivy · Syft · Cosign · kubectl · Helm preinstalados

6 · Trivy en acción — resultados reales

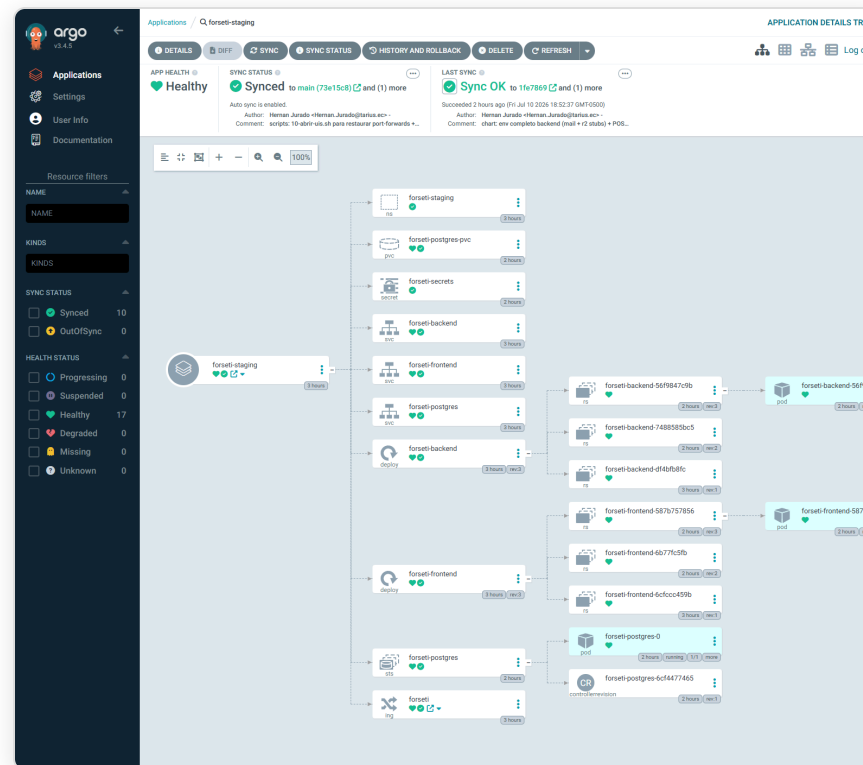
Scan real contra `forseti-backend:local` con **Trivy 0.72.0** — **7 CRITICAL + 8 HIGH** en libs Spring/Thymeleaf. Destacados: `CVE-2026-40477` Thymeleaf **SSTI** · `CVE-2026-22732` Spring Security **bypass** · `CVE-2026-40973` Spring Boot **RCE**.

forseti-backend:local (alpine 3.23.5) - Trivy Report - 2026-07-11 01:10:04.11013028 +0000 UTC m=+0.327714962					
alpine					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	
libexpat	CVE-2026-56131	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/pull/1267 https://nvd.nist.gov/vuln/detail/CVE-2026-56131
libexpat	CVE-2026-56407	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/pull/1262 https://nvd.nist.gov/vuln/detail/CVE-2026-56407
libexpat	CVE-2026-56408	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/commit/1262 https://nvd.nist.gov/vuln/detail/CVE-2026-56408
p11-kit	CVE-2026-2100	HIGH	0.25.5-r2	0.26.2-r0	https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 Toggle more links
p11-kit-trust	CVE-2026-2100	HIGH	0.25.5-r2	0.26.2-r0	https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 Toggle more links
No Misconfigurations found					
jar					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	
com.fasterxml.jackson.core:jackson-databind	CVE-2026-54512	HIGH	2.18.2	2.18.8, 3.1.4, 2.21.4	https://access.redhat.com/security/cve/CVE-2026-54512 https://github.com/FasterXML/jackson-databind/pull/4444 Toggle more links
com.fasterxml.jackson.core:jackson-databind	CVE-2026-54513	HIGH	2.18.2	2.18.8, 2.21.4, 3.1.4	https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/security/cve/CVE-2026-54513 https://bugzilla.redhat.com/show_bug.cgi?id=2264444 Toggle more links
org.apache.httpcomponents.client5:httpclient5	CVE-2025-27820	HIGH	5.4.1	5.4.3	https://access.redhat.com/security/cve/CVE-2025-27820 https://github.com/apache/httpcomponents-client5/pull/1262 Toggle more links
org.apache.tika:tika-core	CVE-2025-66516	CRITICAL	3.0.0	3.2.2	https://access.redhat.com/security/cve/CVE-2025-66516 https://cve.org/CVERecord?id=CVE-2025-66516 https://github.com/apache/tika/pull/1262 Toggle more links
org.apache.tomcat.embed:tomcat-embed-core	CVE-2025-24813	CRITICAL	10.1.34	11.0.3, 10.1.35, 9.0.99	http://www.openwall.com/lists/oss-security/2025/07/11/1 https://access.redhat.com/errata/RHSA-2025-0210 https://access.redhat.com/security/cve/CVE-2025-24813 Toggle more links
org.apache.tomcat.embed:tomcat-embed-core	CVE-2026-41293	CRITICAL	10.1.34	9.0.118, 10.1.55, 11.0.22	http://www.openwall.com/lists/oss-security/2026/07/11/1 https://access.redhat.com/security/cve/CVE-2026-41293 https://github.com/apache/tomcat/pull/1262 Toggle more links
org.apache.tomcat.embed:tomcat-embed-core	CVE-2026-43512	CRITICAL	10.1.34	9.0.118, 10.1.55, 11.0.22	http://www.openwall.com/lists/oss-security/2026/07/11/1 https://access.redhat.com/security/cve/CVE-2026-43512 https://github.com/apache/tomcat/pull/1262 Toggle more links

En Jenkins `trivy image --severity CRITICAL --exit-code 1` **rompe el build** si hay CVE fixable

7 · GitOps con Argo CD — el cluster refleja Git

Regla: el cluster NO acepta cambios directos — todo viene del repo `forseti-devsecops-gitops`. Argo CD **multi-source** combina chart Helm + `values.yaml`. Auditoría automática · Rollback = `git revert`. App `forseti-staging` = **Synced + Healthy**



Tree gráfico — Application → Namespace → Deployments → Pods + PVC + Service + Ingress

8 · Kyverno — última línea de defensa

5 policies enforce activas en el cluster

Policy	Rechaza si...
<code>verify-forseti-image-signatures</code>	Imagen sin firma Cosign válida
<code>require-resource-limits</code>	Container sin <code>requests</code> o <code>limits</code>
<code>disallow-latest-tag</code>	Tag <code>:latest</code> en <code>forseti-prod</code>
<code>disallow-privileged-containers</code>	<code>privileged=true</code> , <code>hostNetwork</code> / <code>PID</code> / <code>IPC</code>
<code>require-run-as-non-root</code>	<code>runAsNonRoot</code> no está en <code>true</code>

Prueba en vivo — Kyverno bloqueando 3 policies al mismo tiempo

```
$ kubectl -n forseti-prod run test-latest --image=nginx:latest --dry-run=server
```

```
Error from server: admission webhook "validate.kyverno.svc-fail" denied the request:
  disallow-latest-tag/block-latest: 'En forseti-prod está prohibido el tag :latest'
  require-resource-limits/validate-limits: 'container debe declarar requests + limits'
  require-run-as-non-root/check-runasnonroot: 'runAsNonRoot debe ser true'
```

9 · Resultados y cierre



Hallazgos de las 7 pruebas: CodeQL 0 críticos · **Trivy 7 CRITICAL + 8 HIGH** en Spring/Thymeleaf · Dep-Check 3 MEDIUM · **ZAP 59 PASS · 0 FAIL** · Gitleaks 0 secretos · Cosign 100% firmadas · Kyverno 3 bloqueos en vivo.



Métricas: commit → staging **≈22 min** · PR **≤5 min** · **0** CVEs CRIT sin mitigar.



Aprendizajes: separar **CI rápido** (GH Actions) de **CD pesado** (Jenkins) funcionó · **Cosign + Kyverno** hacen la firma real · **kind reproducible en 15 min.**



Mejoras: Renovate/Dependabot · Falco runtime · Sealed-Secrets · Argo Rollouts · bump Spring 6.4.6 + Thymeleaf 3.1.4.



github.com/TARIUS-S-A-S/forseti-devsecops (MIT)

Gracias — ¿Preguntas?